COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.6 · Identity & Access Management

Mestre CyberSec · **Aula 4.6 — Identity & Access Management** (12:46) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** IAM: account provisioning (create/config); RBAC (por função) e ABAC (por atributo); SSO (login único federado — SAML/OIDC); service account (credencial de script — gestão especial).

💡 Highlights que a prova CompTIA cobra

- RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar
- SSO: login único — reduz reuso de senha (mais seguro)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'access assigned based on job role'=RBAC

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.6 — Identity & Access Management)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Gestão de Identidade e Acesso (IAM)
Estrutura de políticas e tecnologias que garante que os usuários certos tenham acesso adequado aos recursos; inclui identificação, autenticação, autorização e contabilização.
⚠️ ***Armadilha CompTIA:*** *Na prova, IAM engloba provisionamento, autenticação, autorização e contas; não confunda com um protocolo específico como SAML ou OIDC.*

• Provisionamento de Contas (N/A)
Processo de criar, configurar e conceder acesso a contas de usuário, normalmente durante integração ou mudança de função.
⚠️ ***Armadilha CompTIA:*** *Provisionamento = criar/configurar conta e acessos; desprovisionamento = remover acesso. A prova pode associar ao princípio do menor privilégio.*

• Controle de Acesso Baseado em Função (RBAC)
Modelo de controle de acesso em que permissões são atribuídas a funções, e usuários recebem acesso ao serem colocados na função adequada.
⚠️ ***Armadilha CompTIA:*** *Gatilho: 'access assigned based on job role' = RBAC. Não confunda com ABAC, que usa atributos individuais e contextuais.*

• Controle de Acesso Baseado em Atributos (ABAC)
Modelo de controle de acesso que concede ou nega acesso com base em atributos do usuário, recurso, ação e ambiente.
⚠️ ***Armadilha CompTIA:*** *ABAC é mais granular e dinâmico que RBAC; envolve condições como departamento, hora, local e tipo de dispositivo.*

• Login Único (SSO)
Método de autenticação que permite ao usuário fazer login uma vez e acessar vários aplicativos ou serviços sem redigitar credenciais.
⚠️ ***Armadilha CompTIA:*** *SSO reduz reuso de senha e melhora segurança/UX; na prova, login único federado pode usar SAML ou OIDC.*

• Linguagem de Marcação para Declarações de Segurança (SAML)

Padrão baseado em XML usado para trocar asserções de autenticação e autorização entre um provedor de identidade e um provedor de serviço, comum em SSO corporativo.

⚠️ ***Armadilha CompTIA:*** *SAML = SSO federado corporativo com XML/asserções e IdP/SP. Se a questão citar XML e navegador web, pense SAML.*

• OpenID Connect (OIDC)

Camada de autenticação construída sobre OAuth 2.0 que usa JSON Web Tokens (JWT) para verificar a identidade do usuário e habilitar SSO para web, mobile e APIs.

⚠️ ***Armadilha CompTIA:*** *OIDC = autenticação sobre OAuth 2.0 com JWT/JSON; mais moderno para apps web/mobile. Não é o mesmo que OAuth, que é autorização.*

• Conta de Serviço (N/A)

Conta não humana usada por aplicativo, script ou serviço para acessar recursos; exige gestão especial de credenciais, menor privilégio e rotação.

⚠️ ***Armadilha CompTIA:*** *Conta de serviço não é para login humano; a prova pode cobrar gestão especial de credenciais, rotação e menor privilégio.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Federação de Identidade & Single Sign-On (SSO) - O Passaporte Internacional

🏠 **Analogia Intuitiva:** Pense no passaporte internacional de viagens. Em vez de você ter que tirar uma carteira de identidade diferente para cada país que você visita no mundo (criar um login e uma senha em cada aplicativo web na nuvem), o seu país de origem emite um passaporte oficial e confiável (Identity Provider - IdP). Quando você chega na alfândega do país de destino (Service Provider - SP), os policiais locais examinam o seu passaporte, reconhecem a assinatura diplomática do seu país e deixam você entrar direto, sem exigir que você se cadastre do zero naquele governo.

🔍 **Causa Raiz / Por que foi criado:** A proliferação de dezenas de ferramentas SaaS corporativas causou uma crise de fadiga de senhas (password fatigue), levando colaboradores a reutilizar a mesma senha fraca em todos os sistemas ou anotá-las em blocos de notas inseguros.

🛡️ **Visão do Auditor de GRC:** Auditoria do provisionamento e desprovisionamento centralizado de identidades (protocolo SCIM); conferência de que a desativação da conta do colaborador no IdP central revoga imediatamente seus acessos em todas as aplicações parceiras federadas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'enables users to authenticate once and access multiple disparate systems across different security boundaries' = Identity Federation / SSO. 'Entity that authenticates the user and issues identity assertions' = Identity Provider (IdP).

📌 SAML 2.0 (Security Assertion Markup Language) - O Ofício Notarial em XML

🏠 **Analogia Intuitiva:** O SAML é como uma carta protocolada formal e timbrada em papel moeda especial com carimbo em relevo e fita vermelha enviada pelo cartório central (IdP) para a portaria da empresa parceira (SP). Essa carta protocolada diz em linguagem formal e solene: 'Atestamos sob as penas da lei que o cidadão Carlos fez login com sucesso na sede com senha e biometria às 09:00 e ocupa o cargo de Diretor Financeiro'. O porteiro lê o documento oficial, confere a assinatura digital do cartório e abre as portas do sistema corporativo.

🔍 **Causa Raiz / Por que foi criado:** A necessidade de estabelecer relações de confiança federadas entre corporações e aplicações corporativas em navegadores web sem transferir credenciais de senhas diretamente aos parceiros de negócio.

🛡️ **Visão do Auditor de GRC:** Fiscalização do ciclo de vida e validade dos certificados digitais X.509 de assinatura do SAML; garantia de tempos de expiração restritos para as asserções (máximo de alguns minutos) e verificação de criptografia do token para prevenir interceptação.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'XML-based open standard used primarily for enterprise web browser single sign-on (SSO)' = SAML 2.0. Distrator: SAML usa XML; OIDC usa JSON/JWT.

📌 OAuth 2.0 - A Chave do Manobrista (Delegação de Autorização)

🏠 **Analogia Intuitiva:** A chave do manobrista (valet key) de um carro de luxo. Quando você vai a um restaurante chique, você não entrega a sua chave mestra que abre o porta-luvas com joias e o porta-malas com documentos da empresa; você entrega apenas a chave do manobrista, que só permite ligar o motor e manobrar o carro no estacionamento. O OAuth 2.0 faz exatamente isso: quando um aplicativo de fotos pede para acessar seus contatos, você não digita sua senha mestra nele; você concede um token com escopo restrito que só permite LER contatos, sem poder ver seus e-mails, fotos ou alterar sua senha.

🔍 **Causa Raiz / Por que foi criado:** No passado, aplicativos de terceiros exigiam que os usuários digitassem suas senhas mestras diretamente neles (Anti-Pattern de Credenciais Compartilhadas), expondo contas inteiras caso o aplicativo terceiro fosse invadido.

🛡️ **Visão do Auditor de GRC:** Auditoria dos escopos (Scopes) concedidos a aplicações terceiras no tenant corporativo; revogação de tokens de aplicativos inativos ou excessivamente permissivos e imposição do fluxo Authorization Code Flow com PKCE.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'open framework designed specifically for authorization delegation using scoped access tokens without sharing passwords' = OAuth 2.0. PEGADINHA SUPREMA: OAuth 2.0 é um protocolo de AUTORIZAÇÃO, NÃO de autenticação!

📌 OpenID Connect (OIDC) - O Crachá com Foto Sobre a Chave do Manobrista

🏠 **Analogia Intuitiva:** Se o OAuth 2.0 é a chave do manobrista que autoriza ligar o motor do carro, o OpenID Connect (OIDC) é o crachá com foto oficial de motorista pendurado na chave. O OIDC pega a estrutura leve de tokens do OAuth 2.0 e adiciona uma camada de AUTENTICAÇÃO por cima, entregando um documento de identidade digital chamado ID Token (formatado como JSON Web Token - JWT) que atesta exatamente quem é a pessoa que está no volante.

🔍 **Causa Raiz / Por que foi criado:** Como o OAuth 2.0 foi desenhado apenas para autorização mas todo desenvolvedor tentava usá-lo para fazer login, a indústria padronizou o OIDC para fornecer autenticação segura e moderna em aplicativos móveis e APIs na nuvem.

🛡️ **Visão do Auditor de GRC:** Fiscalização da validação estrita das claims do ID Token (`iss`, `aud`, `exp`) nas APIs corporativas; auditoria da assinatura criptográfica dos JWTs utilizando chaves assimétricas públicas disponibilizadas via endpoint `jwks_uri`.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'authentication protocol built on top of OAuth 2.0 utilizing JSON Web Tokens (JWT) for modern web and mobile apps' = OpenID Connect (OIDC). Regra de ouro: OAuth = Autorização; OIDC = Autenticação.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Mecanismo que permite a um usuário autenticar-se uma única vez e acessar múltiplos sistemas corporativos independentes	**Logon Único (SSO - Single Sign-On)**
Padrão aberto baseado em XML utilizado predominantemente para SSO corporativo e federação de identidades em navegadores web	**SAML 2.0 (Security Assertion Markup Language)**
Framework de segurança projetado para delegação de autorização através de tokens com escopo definido sem expor a senha	**OAuth 2.0**
Camada de autenticação moderna construída sobre o OAuth 2.0 que utiliza JSON Web Tokens (JWT) para verificar a identidade do usuário	**OpenID Connect (OIDC)**
Entidade central em uma arquitetura de federação responsável por autenticar o usuário e emitir os tokens de identidade confiáveis	**Provedor de Identidade (IdP - Identity Provider)**
Aplicação ou serviço corporativo na nuvem que confia nas asserções emitidas pelo Provedor de Identidade para autorizar o acesso	**Provedor de Serviços (SP - Service Provider / Relying Party)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um administrador de sistemas júnior foi encarregado de integrar 15 novos desenvolvedores que entrarão na equipe de engenharia na próxima segunda-feira. O gerente de segurança quer garantir que cada desenvolvedor receba apenas o acesso necessário para sua função, que exista um registro formal das permissões concedidas e que o processo seja repetível para cada contratação futura. Qual processo de IAM melhor atende a todas essas necessidades?

A) Criação manual de contas em cada sistema com permissões personalizadas atribuídas pelo help desk

B) Compartilhar uma única conta genérica de engenharia com todos os novos desenvolvedores via cofre de senhas

C) Implementar um fluxo de trabalho automatizado de provisionamento de contas integrado ao sistema de RH

D) Criar contas com acesso total e remover permissões depois, conforme os gerentes reclamarem

QUESTÃO 2 · CENÁRIO DE EXAME

Uma organização de saúde está projetando um modelo de controle de acesso onde cada enfermeiro deve ter permissões baseadas na ala específica em que trabalha, no turno atribuído e no nível de senioridade. As permissões devem mudar dinamicamente com base nesses atributos contextuais, não apenas em um cargo estático. Qual modelo de controle de acesso é mais apropriado para esse requisito?

A) Controle de Acesso Baseado em Atributos (ABAC) com avaliação baseada em políticas

B) Controle de Acesso Obrigatório (MAC) usando rótulos de segurança eliminando pontos únicos de falha operacional

C) Controle de Acesso Baseado em Função (RBAC) com funções de enfermagem predefinidas em todos os clusters híbridos locais e em nuvem

D) Controle de Acesso Discricionário (DAC) onde os gerentes concedem acesso individualmente

QUESTÃO 3 · CENÁRIO DE EXAME

Após uma auditoria de segurança, a empresa descobriu que a conta de um funcionário desligado permaneceu ativa por três semanas após sua saída, e durante esse período, dados confidenciais de clientes foram exfiltrados usando essas credenciais. O CISO quer impedir que isso aconteça novamente. Qual controle de IAM deve ser implementado como mitigação principal?

A) Implementar rotação obrigatória de senhas a cada 30 dias para todas as contas de usuários

B) Integrar eventos de desligamento do RH com o desprovisionamento automatizado de contas

C) Exigir autenticação multifator em todos os sistemas da organização

D) Bloquear todo o tráfego de saída das contas de usuários durante o horário comercial

QUESTÃO 4 · CENÁRIO DE EXAME

Uma organização usa mais de 40 aplicações SaaS baseadas em nuvem (Salesforce, Workday, GitHub, Jira, etc.) e os usuários reclamam de ter que gerenciar dezenas de senhas diferentes. A equipe de segurança também relata reutilização de senhas e senhas fracas sendo criadas por funcionários frustrados. O CIO aprovou um projeto para permitir que os usuários se autentiquem uma vez e tenham acesso a todas as aplicações aprovadas. Qual tecnologia o arquiteto deve recomendar?

A) Implementar um servidor RADIUS centralizado para todas as aplicações em nuvem

B) Exigir que todos os usuários usem a mesma senha complexa em todas as plataformas

C) Criar uma planilha compartilhada de credenciais de aplicações em uma pasta restrita

D) Implantar uma solução de Single Sign-On (SSO) usando federação SAML ou OIDC

QUESTÃO 5 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento criou um script Python que roda todas as noites para puxar dados de vendas da API do CRM e carregá-los no data warehouse. As credenciais estão atualmente codificadas no código-fonte do script, armazenado em um repositório Git. Um desenvolvedor júnior recentemente publicou acidentalmente o arquivo em um repositório público do GitHub, expondo a chave da API. Qual solução melhor resolve o problema de gerenciamento de credenciais para contas de serviço como essa?

A) Armazenar a credencial da conta de serviço em um cofre de gerenciamento de segredos e recuperá-la em tempo de execução

B) Enviar as credenciais do script por e-mail para todos os desenvolvedores para que possam rotacioná-las manualmente a cada semana

C) Criptografar o script com uma senha e compartilhar a senha verbalmente em reuniões de equipe através de pipelines automatizados de configuração

D) Desativar permanentemente a chave de API e interromper o trabalho de sincronização noturna de dados assegurando conformidade rigorosa de retenção de logs

QUESTÃO 6 · CENÁRIO DE EXAME

O arquiteto de segurança está projetando o controle de acesso para uma aplicação financeira. Existem exatamente 12 funções distintas na empresa (Caixa, Gerente de Agência, Auditor, Administrador de TI, etc.) e cada função possui um conjunto fixo e bem definido de permissões. As permissões mudam apenas quando alguém muda de função, não com base em dados contextuais. Qual modelo é o mais adequado e por quê?

A) Controle de Acesso Baseado em Atributos (ABAC), porque atributos oferecem mais flexibilidade aplicando menor privilégio e reduzindo superfícies de ataque

B) Controle de Acesso Baseado em Regras usando ACLs estilo firewall na camada de aplicação através de pipelines automatizados de configuração

C) Controle de Acesso Baseado em Função (RBAC), porque as permissões se alinham claramente com funções estáticas

D) Controle de Acesso Obrigatório (MAC), porque dados financeiros exigem rótulos de classificação utilizando perfis padronizados de automação de segurança

QUESTÃO 7 · CENÁRIO DE EXAME

Uma organização deseja habilitar SSO entre seu Active Directory local e várias aplicações SaaS em nuvem. O arquiteto precisa de um protocolo de federação que suporte asserções baseadas em XML, possa trocar dados de autenticação e autorização entre o Provedor de Identidade (ADFS) e os Provedores de Serviço (aplicações SaaS), e seja amplamente suportado em ambientes corporativos. Qual protocolo atende melhor a esses requisitos?

A) LDAP (Lightweight Directory Access Protocol) sobre TLS

B) Autenticação Kerberos com tickets de concessão de tickets

C) NTLM (NT LAN Manager) com autenticação pass-through

D) SAML 2.0 (Security Assertion Markup Language)

QUESTÃO 8 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento de aplicações móveis deseja adicionar SSO para que os usuários possam fazer login com suas contas existentes do Google ou Apple em vez de criar novas credenciais. Eles precisam de um protocolo moderno construído sobre o OAuth 2.0 que forneça uma camada de identidade com informações de perfil do usuário (e-mail, nome, foto) retornadas em um JSON Web Token (JWT) padronizado. Qual protocolo deve ser implementado?

A) RADIUS (Remote Authentication Dial-In User Service)

B) OpenID Connect (OIDC) construído sobre OAuth 2.0

C) SAML 2.0 com asserções XML transmitidas via redirecionamentos do navegador

D) PAP (Password Authentication Protocol) com desafio-resposta

QUESTÃO 9 · CENÁRIO DE EXAME

A equipe de operações de segurança detecta que uma conta de serviço usada por uma aplicação de backup tem feito conexões de rede incomuns para um endereço IP externo às 3 da manhã todas as noites. A investigação revela que a senha da conta de serviço não é rotacionada há três anos e está armazenada em texto claro em um arquivo de configuração em 12 servidores diferentes. Qual combinação de controles deve ser implementada para resolver a causa raiz?

A) Implementar cofre de credenciais, impor rotação automática e aplicar privilégio mínimo à conta de serviço

B) Desativar a conta de serviço e migrar o trabalho de backup para rodar interativamente sob uma conta pessoal de administrador

C) Bloquear todo o tráfego de saída na porta 443 no firewall de perímetro durante o horário comercial em todos os endpoints corporativos gerenciados

D) Renomear a conta de serviço e atualizar manualmente o arquivo de configuração nos 12 servidores mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

Um contratante do governo está implementando um sistema de controle de acesso refinado onde o acesso a documentos classificados depende do nível de habilitação do usuário, da classificação do documento, do departamento do usuário, da hora do dia e se o acesso é feito a partir de um dispositivo aprovado. O sistema deve avaliar todos esses fatores juntos antes de conceder acesso. Qual modelo de controle de acesso está sendo descrito?

A) Controle de Acesso Baseado em Função (RBAC) simples usando apenas cargos prevenindo desvios não autorizados de configuração nos nós

B) Controle de Acesso Obrigatório (MAC) com apenas rótulos de habilitação e classificação em todos os endpoints corporativos gerenciados

C) Controle de Acesso Discricionário (DAC) gerenciado individualmente pelos proprietários dos documentos mantendo telemetria e monitoramento contínuos

D) Controle de Acesso Baseado em Atributos (ABAC) com múltiplos atributos avaliados e políticas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Implementar um fluxo de trabalho automatizado de provisionamento de contas integrado ao sistema de RH

O provisionamento automatizado de contas integrado ao sistema de RH é a resposta correta porque garante a criação consistente, repetível e auditável de contas com base em modelos de função (privilégio mínimo), cria automaticamente um registro formal das permissões concedidas e reduz erros humanos. A criação manual (opção A) é propensa a erros e não escalável; contas compartilhadas (opção C) destroem a rastreabilidade; o superprovisionamento (opção D) viola o privilégio mínimo e cria um grande risco de segurança.

Questão 2: Alternativa A — Controle de Acesso Baseado em Atributos (ABAC) com avaliação baseada em políticas

O Controle de Acesso Baseado em Atributos (ABAC) é o correto porque avalia múltiplos atributos (ala, turno, senioridade) dinamicamente contra políticas para tomar decisões de acesso. O ABAC suporta autorização granular e sensível ao contexto, adaptando-se a cenários complexos. O RBAC (opção B) exigiria a criação de centenas de funções estáticas para cada combinação, o que é inviável. O MAC (opção A) usa rótulos de classificação (típico em governo/militares). O DAC (opção D) é controlado pelo proprietário e inadequado para ambientes regulados como saúde.

Questão 3: Alternativa B — Integrar eventos de desligamento do RH com o desprovisionamento automatizado de contas

O desprovisionamento automatizado vinculado a eventos de desligamento do RH é a mitigação principal porque garante que as contas sejam desativadas imediatamente após o término, fechando a janela de oportunidade para uso indevido. O cenário descreve especificamente uma conta obsoleta pós-desligamento sendo usada. A rotação de senhas (opção A) não desativa contas; o MFA (opção C) não impediria o uso da conta ainda ativa, já que as credenciais eram válidas; o bloqueio de tráfego (opção D) é um controle de rede que não aborda o ciclo de vida da identidade.

Questão 4: Alternativa D — Implantar uma solução de Single Sign-On (SSO) usando federação SAML ou OIDC

O Single Sign-On (SSO) usando federação SAML ou OIDC está correto porque permite que os usuários se autentiquem uma vez em um Provedor de Identidade (IdP) central e depois acessem várias aplicações federadas sem reinserir credenciais. Isso elimina a fadiga de senhas, reduz custos de helpdesk e melhora a postura de segurança. RADIUS (opção A) é para autenticação de acesso à rede, não federação SaaS. A mesma senha em todas as plataformas (opção C) é um sério antipadrão de segurança. Uma planilha compartilhada (opção D) destrói a confidencialidade e a rastreabilidade.

Questão 5: Alternativa A — Armazenar a credencial da conta de serviço em um cofre de gerenciamento de segredos e recuperá-la em tempo de execução

Armazenar a credencial da conta de serviço em um cofre de gerenciamento de segredos (HashiCorp Vault, AWS Secrets Manager, Azure Key Vault) e recuperá-la em tempo de execução é a solução correta porque elimina credenciais codificadas, suporta rotação automática, fornece auditoria de acesso e evita exposição em texto claro no controle de origem. Enviar credenciais por e-mail (opção A) é inseguro e não escalável. Criptografar scripts (opção C) ainda exige distribuição de segredos e não resolve a causa raiz. Desativar o trabalho (opção D) abandona o requisito de negócio.

Questão 6: Alternativa C — Controle de Acesso Baseado em Função (RBAC), porque as permissões se alinham claramente com funções estáticas

O Controle de Acesso Baseado em Função (RBAC) é o mais adequado porque o cenário descreve um conjunto pequeno e bem definido de funções estáticas com conjuntos de permissões fixos que mudam apenas quando as funções mudam. O RBAC se destaca nesse tipo de ambiente: simples de gerenciar, fácil de auditar e se alinha perfeitamente com a estrutura organizacional. O ABAC (opção A) é exagerado quando não há atributos contextuais a serem avaliados. ACLs baseadas em regras (opção B) operam em camadas de rede, não em camadas de identidade. O MAC (opção D) é para ambientes governamentais classificados, não para finanças comerciais típicas.

Questão 7: Alternativa D — SAML 2.0 (Security Assertion Markup Language)

SAML 2.0 é a resposta correta porque é um padrão de federação baseado em XML explicitamente projetado para trocar asserções de autenticação e autorização entre um Provedor de Identidade e Provedores de Serviço, e é o protocolo de federação dominante em integrações SaaS corporativas. LDAP (opção A) é um protocolo de acesso a diretório, não um protocolo de asserção de federação/autenticação. Kerberos (opção C) é excelente para ambientes locais, mas não é um protocolo de federação para SaaS em nuvem. NTLM (opção D) é um protocolo de autenticação desatualizado e inseguro.

Questão 8: Alternativa B — OpenID Connect (OIDC) construído sobre OAuth 2.0

OpenID Connect (OIDC) está correto porque é uma camada de identidade moderna construída sobre OAuth 2.0, retornando tokens de identidade JWT padronizados contendo declarações de perfil do usuário (e-mail, nome, foto). É o padrão de fato para SSO de nível consumidor (contas Google, Apple, Microsoft) e aplicações web/móveis modernas. RADIUS (opção A) é para acesso à rede. SAML 2.0 (opção B) usa XML e é mais comum em federação corporativa, não otimizado para identidade móvel/consumidor. PAP (opção D) é um protocolo de autenticação obsoleto e inseguro.

Questão 9: Alternativa A — Implementar cofre de credenciais, impor rotação automática e aplicar privilégio mínimo à conta de serviço

Cofre de credenciais (ex.: AWS Secrets Manager, HashiCorp Vault), rotação automática e privilégio mínimo são a combinação correta porque abordam diretamente as causas raiz: armazenamento em texto claro, ausência de rotação e permissões provavelmente excessivas. Esses controles são o padrão para o gerenciamento seguro de contas de serviço. Desativar e migrar para contas pessoais (opção A) destrói a rastreabilidade. Bloquear tráfego (opção C) é um curativo que não resolve o problema de credenciais. Renomeação manual (opção D) não resolve o problema de armazenamento ou rotação e é operacionalmente frágil.

Questão 10: Alternativa D — Controle de Acesso Baseado em Atributos (ABAC) com múltiplos atributos avaliados e políticas

O Controle de Acesso Baseado em Atributos (ABAC) é o correto porque avalia múltiplos atributos (habilitação, classificação, departamento, hora, dispositivo) contra políticas para tomar decisões de acesso sensíveis ao contexto. O ABAC suporta a avaliação complexa e multifatorial descrita no cenário. O RBAC puro (opção A) não pode considerar contexto de hora ou dispositivo. O MAC (opção B) normalmente usa apenas habilitação e classificação, não departamento/hora/dispositivo. O DAC (opção D) é controlado pelo proprietário e não imporia essas políticas centralizadas e multifatoriais.